TK/MUNDAT Blueprint and Rego Rules Analysis

A plain-language analysis of TK_description.pdf, data/tk_mundat_data_sharing_v2.json, and policies/tk/*.rego

Purpose. This report explains the MUNDAT use case, assesses how well the v2 blueprint represents it, and explains what the six Rego rules check. The analysis is about design-time evidence: it checks what the blueprint declares before execution. It is not a legal opinion and does not prove that controls will work at runtime.

1. What the TK/MUNDAT case is

The source document describes Trondheim Municipality receiving requests from researchers, companies, public organisations and other consumers who want municipal data. The municipality needs a consistent process to decide what data can be shared, identify the relevant systems, extract and combine data, protect sensitive information, complete compliance checks, and deliver the result securely or publish an anonymised open dataset.

The two example datasets are **Sickleave**, which combines HR and related information and may contain personal data, and **IoT** stormwater sensor data, which is described as non-personal open data. The main MUNDAT activities are: receive request; perform DPIA and risk assessment; identify sources; extract data; integrate data; assess and apply anonymisation where needed; perform the final risk assessment; and share the dataset securely.

The document also identifies roles such as Data Consumer, Data Provider, Data Protection Officer, Compliance Process Owner, Data Engineer, Information Security Expert and Service Owner. Its requirements include a single request entry point, automated compliance support, metadata and lineage, protection of sensitive data, contract management, secure delivery, and encryption at rest and in transit (TK_description.pdf, pages 55-62).

2. How well the v2 blueprint reflects MUNDAT

Overall, the blueprint is a good simplified structural model of the MUNDAT sharing workflow. It is especially strong for demonstrating the InspectR proof of concept: it has a request, classification, compliance gates, two sources, processing, integration, anonymisation, approval and transfer. However, it is not a complete implementation of every MUNDAT requirement.

MUNDAT activity or requirement	Blueprint representation	Assessment
Receive and route a data request	The **request** node contains a request ID, academic requester, purpose and legal basis. The connections begin with request intake and classification.	**Strong match.** It demonstrates a single, traceable request entry in the blueprint.
Classify data and identify sensitivity	**classify_request** declares personal data and special-category data. The two data sources also declare their data profiles and fields.	**Good match.** It captures the risk trigger and source-level metadata.
DPIA and risk assessment	**dpia_check** declares DPIA required, DPIA completed and risk assessment completed.	**Partial match.** The blueprint has one early gate, while MUNDAT describes risk assessments at several stages, including after integration and before sharing.
Identify and extract data	**citizen_registry** and **health_services** feed **extract_data**. Owners, fields, storage and retention are included.	**Good structural match.** The blueprint does not model the municipality's many systems in full, but it shows the needed pattern.
Integrate data	**integrate_dataset** receives both sources and declares schema documentation, lineage and provenance.	**Strong match.** This directly supports the lineage and traceability objectives.
Protect sensitive data	**anonymisation** declares anonymisation and re-identification risk assessment.	**Good but simplified.** The source document mentions aggregation, masking and pseudonymisation as well. The rule set does not verify this node.

MUNDAT activity or requirement	Blueprint representation	Assessment
Purpose and sharing approval	**sharing_assessment** declares compatible purpose, contract, approved recipient and sharing agreement.	**Good match.** It captures the governance decision before transfer, but the actual legal documents are not included.
Secure delivery	**share_dataset** declares encryption in transit, approved recipient, audit trail and an open-data-portal destination.	**Good structural match.** Encryption at rest is declared for one source but not consistently for both sources.
Open versus protected data	The destination is Trondheim's open data portal, while the workflow also contains a contract and recipient approval.	**Potential ambiguity.** The source case distinguishes anonymised open data from protected data under formal contracts. The blueprint should explicitly state which route applies.

3. Important gaps and inconsistencies

• The source document describes multiple risk-assessment points. The blueprint has a DPIA/risk gate before the source nodes, but no separate post-integration or pre-sharing risk-assessment gate.

• The health_services schema marks sick_leave_reasons as PII with masking_strategy none, while the anonymisation node says anonymisation was applied. The blueprint should explain how this field is protected or removed.

• The blueprint says the destination is an open data portal, but it also models a data-sharing agreement and recipient approval. That can be valid, but the open-public route and protected-recipient route should be distinguished explicitly.

• Encryption at rest is true for health_services but false for citizen_registry. This may be intentional, but it conflicts with the MUNDAT non-functional requirement if both sources require storage protection.

• The blueprint has useful fields for consent, contracts, retention, owners, audit trail and legal basis, but the Rego rules do not check most of them.

• The rules mainly check Boolean declarations. They do not open or validate the DPIA, risk assessment, agreement, approval record, lineage record, encryption configuration or anonymisation result.

4. What the Rego rules are

Rego is the policy language used by Open Policy Agent (OPA). Each rule reads the JSON blueprint, finds relevant nodes and properties, and returns a report with a rule ID, status, legal reference, reason, evidence and remedy. The aggregator in policy.rego returns the six reports together.

In simple terms, the rules work like checklists. They first decide whether a condition is present, such as sensitive data or a transfer. If the condition is present, they look for a required control. A PASS means the expected declaration was found, or the rule considered itself not applicable. A FAIL means a required control was explicitly false, or, for TK-006, missing. HUMAN means the metadata is not enough for a safe automated decision.

Rule and result	Simple meaning and check	What PASS means here
TK-001 - PASS DPIA	Finds a data source with both personal data and special-category data. Then checks a compliance gate for **dpia_completed: true**.	health_services triggers the DPIA check and dpia_check declares completion. This proves the blueprint records a completed DPIA; it does not inspect the DPIA.
TK-002 - PASS Risk assessment	Finds special-category data and checks **risk_assessment_completed: true** on a compliance gate.	health_services is sensitive and dpia_check declares a completed risk assessment. The assessment document itself is not validated.
TK-003 - PASS Sharing agreement	Checks whether personal data and a data_transfer node are present. If so, it requires **data_sharing_agreement_exists: true**.	The sources contain personal data, share_dataset is a transfer, and sharing_assessment declares an agreement. The agreement's legal content is not checked.

Rule and result	Simple meaning and check	What PASS means here
TK-004 - PASS Lineage	Finds data_integration nodes and requires **lineage_available: true**.	integrate_dataset declares lineage. The rule does not inspect the actual lineage graph; it only checks the Boolean.
TK-005 - HUMAN Purpose compatibility	Checks every compliance gate. A missing, null or non-true **purpose_compatible** causes HUMAN.	sharing_assessment says true, but dpia_check is also a compliance gate and has no purpose_compatible field. Therefore the rule escalates to human review. This is conservative and exposes a modelling issue.
TK-006 - PASS Sharing safeguards	Looks up exact node IDs and requires five values to be exactly true: DPIA, risk assessment, agreement, recipient approval and encryption in transit.	All five controls are true in the v2 blueprint, so the composite checklist passes. It does not verify that the controls operate in reality.

5. What the results mean in plain language

The OPA evaluation says: the blueprint declares that sensitive data is handled with a completed DPIA and risk assessment; personal data is shared under a declared agreement; the integration step declares lineage; all five sharing safeguards in TK-006 are declared; but purpose compatibility cannot be automatically accepted because one of the two compliance gates has no purpose compatibility decision.

Most important limitation: these results are evidence of a designed control structure, not proof of real-world legal compliance. A person still needs to check the actual DPIA, risk assessment, contract, purpose analysis, recipient authorisation, anonymisation quality, lineage records and technical security configuration.

6. Recommended improvements

• Add a separate risk-assessment gate after integration and another immediately before sharing, matching the MUNDAT process description.

• Add an explicit route field such as open_anonymised_data or protected_contract_data, and ensure the destination and required controls agree with that route.

• Resolve the health_services masking inconsistency by documenting protection for sick_leave_reasons and validating that the anonymisation step covers every sensitive field.

• Set or clarify encryption-at-rest expectations for every source.

• Move purpose_compatible to a dedicated sharing-purpose gate, or add it consistently to every gate that TK-005 examines. This would avoid an unintended HUMAN result caused only by the DPIA gate's missing field.

• Extend evidence beyond Booleans: include document IDs, versions, reviewers, dates, recipient identity, agreement references, lineage details and encryption configuration.

Bottom line: The v2 blueprint is a credible and useful simplified MUNDAT example for demonstrating design-time policy inspection. It reflects the main pipeline stages and produces mostly positive rule results. It should not be presented as a complete model of the TK case or as evidence that the municipality is legally compliant without the underlying documents and runtime verification.